

CURSO

PROCESSO DE GESTÃO DE RISCOS DE PRIVACIDADE

Módulo I

Diretrizes e práticas para identificar, avaliar, tratar, monitorar e comunicar riscos de privacidade na ANAC.



PROTEGER
INFORMAÇÕES



PRESERVAR A
PRIVACIDADE



GARANTIR
CONFORMIDADE



FORTALECER A
GOVERNANÇA

Conectar para **transformar**
e **proteger** o que importa.



Conteúdo

Módulo I:

1. APRESENTAÇÃO GERAL
2. INTRODUÇÃO
 - a. Escopo;
 - b. Público-alvo
3. HISTÓRICO
 - a. Por que gerenciar riscos de privacidade e proteção de dados nos dias de hoje?
4. PRINCIPAIS ATORES DO PROCESSO
5. PRINCIPAIS CONCEITOS
6. VISÃO GERAL DO PROCESSO
7. ESTABELECIMENTO DO CONTEXTO
 - a. Definir gestor de riscos;
 - b. Definir objetivos, premissas, restrições e escopo do processo de GRPSI;
 - c. Validar objetivos, premissas, restrições e escopo do processo de GRPSI;
 - d. Definir Responsáveis Pelas Unidades Organizacionais;
 - e. Definir Responsáveis Por Ativos.
8. ESTUDO DE CASO – PARTE I
9. REFERÊNCIAS BIBLIOGRÁFICAS



Ao final deste Módulo, esperamos que você seja capaz de:

- I – Conheça os principais conceitos sobre o processo de Gestão de Risco de Privacidade e Segurança da Informação - GRPSI;
- II – Tenha uma visão geral sobre o processo de GRPSI;
- III – Consiga estabelecer o contexto de GRPSI, incluindo a proposição dos objetivos, escopo e limites da avaliação de riscos a ser realizada;

1. APRESENTAÇÃO GERAL

Este material apresenta o Processo de Gestão de Riscos de Privacidade e Segurança da Informação (GRPSI) no âmbito da Agência Nacional de Aviação Civil – ANAC, com enfoque na Lei 13.709, que versa sobre a Proteção de Dados Pessoais - LGPD.

O processo aplica-se a todas as unidades organizacionais da ANAC e a seus colaboradores que tratem ou tenham acesso a ativos de informação ou dados pessoais sob responsabilidade da Agência.

São objetivos específicos deste evento de capacitação:

- I. Proteger os ativos de informação da ANAC;
- II. Garantir a continuidade dos processos regulatórios e administrativos da Agência;
- III. Assegurar a conformidade com os requisitos legais, normativos e institucionais aplicáveis; e
- IV. Proteger os direitos e as liberdades fundamentais dos titulares de dados pessoais; e
- V. Contribuir para o cumprimento da Política Nacional de Segurança da Informação e da Lei Geral de Proteção de Dados Pessoais - LGPD.

2. INTRODUÇÃO

Este evento de capacitação se baseia no manual para implantação do processo de **Gestão de Risco de Privacidade e Segurança da Informação – GRPSI**, no âmbito da ANAC, subsidiando conhecimentos que permitirão a definição de diretrizes e procedimentos para identificar, analisar, avaliar, tratar, monitorar e comunicar riscos associados a ativos de informação e ao tratamento de dados pessoais.

Este material apresenta o Processo de Gestão de Riscos de Privacidade e Segurança da Informação (GRPSI) no âmbito da Agência Nacional de Aviação Civil – ANAC, com enfoque na Lei 13.709, que versa sobre a Proteção de Dados Pessoais - LGPD.

Escopo

O processo de GRPSI aplica-se aos ativos críticos de informação e privacidade da ANAC.

Os ativos críticos de informação da ANAC deverão ser formalmente definidos pela Superintendência de Tecnologia e Transformação Digital - STD, enquanto os ativos críticos de privacidade serão definidos pela Assessoria Técnica - ASTEC, devendo ambos serem submetidos à aprovação do Comitê de Segurança da Informação e de Proteção de Dados Pessoais - CSIP.

A monitoração e avaliação do processo ficará a cargo do gestor de segurança da informação e do encarregado pelo tratamento de dados pessoais, no âmbito de suas respectivas competências.

Ressaltamos que este curso terá como foco principal a gestão de risco dos ativos de privacidade.



Público-Alvo

I - Aos indivíduos responsáveis pela gestão ou que utilizem ativos de informação ou tratem dados pessoais no âmbito da ANAC; e

II - A provedores de serviços e entidades terceirizadas que tenham acesso a ativos de informação, redes, sistemas ou dados pessoais sob responsabilidade da ANAC.

3. HISTÓRICO

Breve histórico e evolução da proteção de dados e gestão de riscos de privacidade

A gestão de riscos em segurança da informação nasceu da necessidade técnica de proteger dados armazenados em sistemas computacionais, evoluindo progressivamente para um componente vital da governança corporativa.

Historicamente, essa prática consolidou-se em torno da tríade **CIA**:

- ✓ Confidencialidade;
- ✓ Integridade;
- ✓ Disponibilidade.



Referenciais como a norma britânica BS 7799 pavimentaram o caminho para a série ISO/IEC 27000, que hoje padroniza os sistemas de gestão de segurança em nível global. Inclusive, este evento de capacitação segue o ciclo contínuo de Gestão de Riscos recomendado pela Norma ABNT NBR ISO/IEC 27005.

Com o avanço da sociedade da informação e do comércio eletrônico, a **privacidade** emergiu como uma preocupação central, transformando a proteção de dados pessoais de uma questão puramente técnica em uma obrigação legal e estratégica.

Marcos como o Regulamento Geral sobre a Proteção de Dados na Europa e a Lei Geral de Proteção de Dados no Brasil mudaram o paradigma: as organizações deixaram de focar apenas na segurança dos perímetros tecnológicos para focar na jornada e no direito do titular do dado.

Por que gerenciar riscos de privacidade e proteção de dados nos dias de hoje?

No cenário contemporâneo, a gestão de riscos de privacidade não é mais opcional, mas um requisito de sustentabilidade por diversos motivos críticos:

- **Conformidade "Auditável" (LGPD):** O Brasil vive uma transição da conformidade meramente declaratória para uma conformidade auditável. A Autoridade Nacional de Proteção de Dados (ANPD) tem intensificado a fiscalização, exigindo que empresas provem, com evidências concretas, como os dados são tratados e protegidos.
- **A Inteligência Artificial como Ameaça Central:** Para o ano de 2026, a Inteligência Artificial já é considerada o maior risco para as empresas no Brasil. O uso de ferramentas de IA sem governança aumenta drasticamente o risco de vazamento de dados e criar novos vetores para crimes cibernéticos.
- **Impacto no Valor do Negócio e Crises:** Incidentes cibernéticos são o sexto maior gerador de crises globais em negócios. Mais do que uma falha técnica, uma violação de privacidade causa danos severos à reputação, perda de confiança pela sociedade e sanções judiciais que podem inviabilizar as operações de uma empresa.
- **Privacidade como Requisito Contratual:** A proteção de dados deixou de ser um diferencial de marketing para se tornar um pré-requisito de contrato em toda a cadeia econômica. Parceiros e clientes exigem provas de que a organização controla acessos, gerencia fornecedores e possui planos efetivos de resposta a incidentes.
- **Evolução tecnológica:** O crime cibernético mudou seu foco de apenas criptografar dados para a extorsão baseada no vazamento de informações sensíveis. Sem uma gestão de riscos preditiva e preventiva, as organizações ficam vulneráveis a interrupções operacionais e danos irreparáveis à imagem.



4. PRINCIPAIS ATORES DO PROCESSO

Na Gestão de Riscos de Privacidade e Segurança da Informação, os atores atuam diretamente em todas as etapas do processo e a definição clara de suas atribuições e competências permite uma governança eficiente e uma tomada de decisão baseada em responsabilidades bem delineadas.



Agente de
gestão de riscos

Agente responsável pela gestão de riscos de privacidade e segurança da informação: servidor efetivo responsável por elaborar o plano de gestão de riscos de privacidade e segurança da informação, o relatório de identificação, análise e avaliação dos riscos de privacidade e segurança da informação e o relatório de tratamento de riscos de privacidade e segurança da informação.



Autoridade
Competente

Autoridade Competente: responsável por prover os recursos necessários à gestão de riscos; identificar responsáveis; iniciar as atividades de gestão de riscos. Na ANAC, essa função é exercida pela liderança do CSIP.



CSIP

CSIP: Comitê de Segurança da informação e de Proteção de Dados Pessoais.



Encarregado
(DPO)

Encarregado: pessoa indicada pelo controlador (ANAC) para atuar como canal de comunicação entre o controlador, os titulares dos dados pessoais e a Autoridade Nacional de Proteção de Dados - ANPD. No escopo da gestão de riscos, é responsável por coordenar a gestão de riscos de privacidade, designar o agente responsável pela gestão de riscos de privacidade, aprovar o plano de gestão de riscos de privacidade e os relatórios de identificação, análise, avaliação e tratamento dos riscos de privacidade, bem como propor medidas preventivas à alta administração.



Gestor
de riscos

Gestor de riscos: é o agente responsável pela gestão de riscos de privacidade e/ou segurança da informação;



Responsável
pela Unidade
Organizacional

Responsável pela Unidade Organizacional: responsável por uma área da organização na qual a metodologia será implementada. Tem o papel de coordenar o fornecimento das informações necessárias à identificação e à estimativa de riscos e realizar melhorias necessárias quando as análises indicarem.



Responsável
por ativos

Responsável por ativos: responsável por fornecer informações sobre os ativos que fazem parte da análise de riscos. Essas informações auxiliam a tomada de decisões sobre controles a serem implementados.



Titular

Titular: pessoa natural a quem se referem os dados pessoais que são objeto de tratamento.

5. PRINCIPAIS CONCEITOS

- **Ativo:** tudo que tem valor para a organização, material ou não;
- **Ativos de informação:** meios de armazenamento, transmissão e processamento da informação, equipamentos necessários a isso, sistemas utilizados para tal, locais onde se encontram esses meios, recursos humanos que a eles têm acesso e conhecimento ou dado que tem valor para um indivíduo ou organização;
- **Controle:** forma de gerenciar o risco, incluindo políticas, procedimentos, diretrizes, práticas, estruturas organizacionais, que podem ser de natureza administrativa, técnica, de gestão ou legal;
- **Mapa de Risco:** documento ou representação sistematizada que consolida os riscos identificados em um determinado escopo organizacional, indicando suas causas, probabilidades, impactos, níveis de criticidade e medidas de tratamento definidas;
- **Risco:** no sentido amplo, trata-se da possibilidade de ocorrência de um evento que pode impactar o cumprimento dos objetivos. Pode ser mensurado em termos de impacto e de probabilidade;

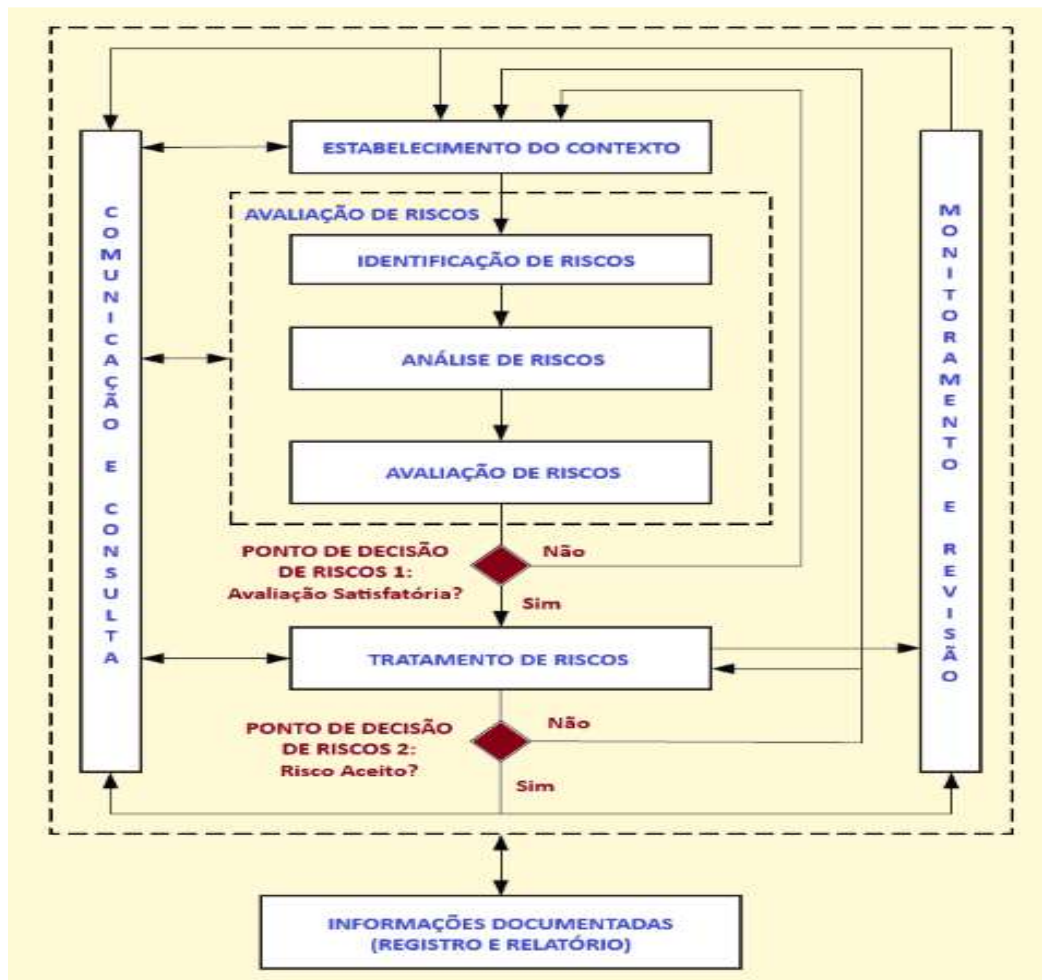


6. VISÃO GERAL DO PROCESSO

O processo estabelecido para implantação na ANAC segue o ciclo contínuo de Gestão de Riscos recomendado pela Norma ABNT NBR ISO/IEC 27005:2022.

Mais do que uma simples sequência de tarefas, este fluxo representa uma metodologia dinâmica e iterativa, projetada para garantir que a organização responda de forma ágil às incertezas do ambiente digital.

Ao adotar este fluxo, a organização deixa de agir de forma reativa a incidentes e passa a operar um sistema de gestão preventivo, onde cada risco é identificado, tratado e monitorado de forma sistemática e estruturada.



Como resultado da execução da fase de avaliação e tratamento dos riscos deverão constar os seguintes documentos, respectivamente:

- ✓ Relatório de identificação, análise e avaliação dos riscos (Anexo III).
- ✓ Relatório de tratamento de riscos (Anexo IV).

7. ESTABELECIMENTO DO CONTEXTO

Compreende a proposição dos objetivos, escopo (estrutura funcional, processo, sistema, recurso ou determinado ativo) e limites da avaliação de riscos a ser realizada. Neste contexto, devem ser observadas as Políticas de Segurança da Informação, de Proteção de Dados Pessoais e de Gestão de Integridade, de Riscos Corporativos e de Continuidade de Negócios da ANAC.

Essa fase é composta pelas seguintes tarefas:



I. Definir gestor de riscos

O gestor de segurança da informação e o encarregado pelo tratamento de dados pessoais deverão designar formalmente o gestor de riscos para a condução das próximas atividades do processo de GRPSI, no âmbito de suas respectivas competências.

II. Definir objetivos, premissas, restrições e escopo do processo de GRPSI

O gestor de riscos deve iniciar o processo de GRPSI e informar os objetivos genéricos (de alto nível) e os objetivos específicos, tais como, informações confidenciais, sistemas que requerem alta disponibilidade, sistemas e informações cruciais para a tomada de decisões etc.

Além disso, o gestor de riscos deve identificar e descrever os tipos de restrições que se apliquem, tais como questões técnicas, jurídicas, financeiras, de prazos etc.

O gestor de riscos deve identificar também as unidades dentro do escopo do processo de GRPSI, e seus respectivos responsáveis, assim como as que estão fora do escopo do processo.

III. Validar objetivos, premissas, restrições e escopo do processo de GRPSI.

O gestor de segurança da informação e o encarregado pelo tratamento de dados pessoais deverão verificar, no âmbito de suas respectivas competências, se as informações definidas nas tarefas anteriores são estratégicas e se estão alinhadas às necessidades e às expectativas da organização.

Caso estejam de acordo, deverão registrar a aprovação do processo de GRPSI.

IV. Definir Responsáveis Pelas Unidades Organizacionais

O Gestor de Riscos deve identificar os profissionais que assumirão os papéis de Responsáveis Pelas Unidades Organizacionais.

V. Definir Responsáveis Por Ativos

Os Responsáveis Pelas Unidades Organizacionais devem identificar os profissionais que assumirão os papéis de Responsáveis Por Ativos em cada unidade e posteriormente notificar o gestor de riscos.

8. ESTUDO DE CASO – PARTE I

Visando contextualizar o conhecimento aprendido neste módulo e criar uma ponte entre a teoria e a prática do dia a dia, analisaremos um estudo de caso em que iremos estabelecer contextos e propor a implementação de controles para tratamentos de riscos identificados dentro de um cenário hipotético.

Cenário Inicial: A ANAC identificou a necessidade de realizar uma



avaliação de riscos específica para o sistema que gerencia os Certificados Médicos Aeronáuticos (CMA), visto que ele trata dados pessoais sensíveis de milhares de regulados. O primeiro passo foi **estabelecer o contexto** conforme o rito oficial da GRPSI:

1. Definição do Gestor de Riscos

O **Gestor de Segurança da Informação** e o **Encarregado pelo Tratamento de Dados Pessoais** da ANAC designarão formalmente um servidor efetivo da Agência para atuar como o **Gestor de Riscos** deste processo. Sua missão será coordenar as atividades e garantir que o relatório final seja elaborado com precisão técnica.

2. Definição de Objetivos, Escopo e Restrições

O Gestor de Riscos se reunirá com as áreas interessadas para delimitar o trabalho:

- **Objetivos Específicos:** Proteger a confidencialidade dos dados de saúde dos pilotos e garantir a conformidade auditável perante a LGPD, evitando vazamentos que gerem sanções ou danos à reputação da Agência.
- **Escopo:** O foco será restrito ao módulo de acesso externo do Sistema Integrado de Informações da Aviação Civil - SACI, identificado como o ponto de maior exposição para usuários externos.
- **Restrições:** Inicialmente foram identificadas restrições financeiras (orçamento limitado para aquisição imediata de novas ferramentas de criptografia) e de prazos (necessidade de conclusão da análise em 30 dias devido a uma auditoria iminente).

3. Validação do Contexto

As definições de escopo e objetivos foram submetidas ao **Encarregado** e ao **Gestor de Segurança da Informação**, que verificaram o alinhamento estratégico com a Política de Proteção de Dados da ANAC e registraram a aprovação formal para o início dos trabalhos.

4. Identificação dos Atores da Unidade e dos Ativos

Para operacionalizar a coleta de informações, foram definidos os seguintes papéis:

- **Autoridade Competente:** A liderança do **CSIP** (Comitê de Segurança da Informação e de Proteção de Dados Pessoais), responsável por prover recursos.
- **Responsável pela Unidade Organizacional:** O titular da área técnica que utiliza o sistema, que será o responsável por coordenar o fornecimento de dados.
- **Responsável por Ativos:** O gerente de área responsável que administra a manutenção do banco de dados do SACI e que fornecerá os detalhes técnicos sobre a autenticação e os logs de acesso.

Conclusão da Etapa: Com o contexto estabelecido, os objetivos validados e os atores devidamente identificados, a organização está pronta para avançar para a fase de **Identificação de Riscos**, conforme abordaremos no Módulo 2 deste curso, onde realizaremos análise mais aprofundada do cenário dentro da metodologia proposta.

9. REFERÊNCIAS BIBLIOGRÁFICAS

1. AGÊNCIA NACIONAL DE AVIAÇÃO CIVIL. **Processo de gestão de privacidade segurança da informação**. Brasília: ANAC, 2026. 29 p.
2. **FERREIRA, Douglas Favaro**. *Análise e Avaliação de Riscos de Segurança da Informação: Um estudo de caso baseado nas melhores práticas da ISO/IEC 27005*. Americana, SP: Faculdade de Tecnologia de Americana, 2015.
3. **PACHECO, Igor**. *Tendências de segurança de dados e informação para 2026: o que já mudou e como se preparar*. Data Guide, 30 jan. 2026.
4. ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **Segurança da informação, segurança cibernética e proteção à privacidade: controles de segurança da informação** = Information security, cybersecurity and privacy protection: information security controls. 3. ed. Rio de Janeiro, 2022. (ABNT NBR ISO/IEC 27002:2022)
5. ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **Segurança da informação, segurança cibernética e proteção à privacidade: orientações para gestão de riscos de segurança da informação** = Information security, cybersecurity and privacy protection: Guidance on managing information security risk. 4. ed. Rio de Janeiro, 2023. (ABNT NBR ISO/IEC 27005:2023)
6. ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **Segurança da informação, segurança cibernética e proteção da privacidade: sistemas de gestão da privacidade da informação: requisitos e orientações** = Information security, cybersecurity and privacy protection : privacy information management systems : requirements and guidance. 2. ed. Rio de Janeiro, 2026. (ABNT NBR ISO/IEC 27701:2026)